ISO/IEC 27001 COMPLIANCE FRAMEWORK CAPSTONE PROJECT

Name: Jemimah Jacobs

Role: Junior GRC Consultant

Course Code: (C26-06)

Submission Date: August 22nd, 2026

About NovaCare

NovaCare Health Services is a growing healthcare provider operating three outpatient clinics across Ghana. The organisation manages patient records, appointment scheduling, payroll, supplier information, and financial transactions using both cloud-based and on-premises systems. As the organisation has expanded, management has identified the need to formalise information security governance and pursue certification against ISO/IEC 27001.

1. **ISMS Scope Statement**

The Information Security Management System (ISMS) for NovaCare Health Services covers all people, processes, and technology involved in the creation, processing, storage, and transmission of patient records, appointment scheduling data, payroll information, supplier information, and financial transaction data, across all three outpatient clinics.

- **Location:** All three outpatient clinic locations
- **People:** Employees, contractors, and third-party suppliers who access, process, or manage NovaCare information assets
- **Departments:** IT, Clinical, and Administration
- **Governance activities in scope:** Policy management, risk assessment, incident management, and supplier due diligence
- **Information Assets:**
- Patient information
- Payroll information
- Supplier information
- Financial transaction records
- **Systems in scope:**
- Appointment-scheduling systems
- Cloud-based platforms
- On-premises systems

Exclusions: No business functions, locations, or systems are excluded from this ISMS scope at this stage.

2. **Review of Current Security Practices**

   A review of NovaCare's existing documentation and stakeholder interviews (IT, clinical, and administrative staff) found that information security is currently managed informally.
   1. No ISMS scope, formal policy suite, or risk register exists, one stakeholder noted that "we don't have a formal risk register, decisions on security are made case-by-case."
   2. Control implementation is inconsistent across the three clinics, supplier security is not formally vetted, and staff do not receive regular security awareness training.

3. **Gap Analysis**

   This informal state was assessed against ISO/IEC 27001 Clauses 4–10 and the 93 Annex A controls to produce the gap analysis below.

Identified Gap	ISO 27001	Annex A Category	Recommended Control	Priority
No formally defined ISMS scope; boundaries of protected systems, clinics, and data are undocumented.	Clause 4.3	Organisational	A.5.1 – Policies for Information Security (supported by a documented ISMS Scope Statement)	High
Information security policies are incomplete, outdated, or not formally approved by management.	Clause 5.2 / A.5.1	Organisational	A.5.1 – Policies for Information Security	High
No formal information asset inventory; patient records, payroll, and supplier data are not classified or tracked.	A.5.9	Organisational	A.5.9 – Inventory of Information Assets; A.5.12 – Classification of Information	High
Risk assessments are performed inconsistently and there is no formal risk register (decisions made case-by-case).	Clause 6.1.2	Organisational	A.5.9 (asset basis for risk) supported by a formal risk assessment methodology and risk register	High
Security controls have	Clause	Organisational	Formal SoA development	Medium

not been formally selected or documented — no Statement of Applicability (SoA) exists.	6.1.3		referencing all 93 Annex A controls with inclusion/exclusion justification	
Security awareness training is not conducted regularly for clinical, IT, and admin staff.	A.6.3	People	A.6.3 – Information Security Awareness, Education & Training	Medium
Supplier security requirements are not consistently evaluated before onboarding third parties.	A.5.19 / A.5.20	Organisational	A.5.19 – Information Security in Supplier Relationships; A.5.20 – Addressing Security Within Supplier Agreements	Medium

4. Annex A Control Recommendations

The following control recommendations are prioritised by the risk each gap represents to NovaCare's core assets: patient records (confidentiality and regulatory risk), financial and payroll data (integrity and fraud risk), and clinic operations (availability risk).

- A.5.1 – Policies for Information Security: Draft a top-level information security policy, obtain management approval, and communicate it to relevant stakeholders. Subordinate policies, such as access control, acceptable use and data classification, can then be developed from it.
- A.5.9 – Inventory of Information Assets: Build a register of information assets across all three clinics, including patient records systems, payroll systems, and supplier data stores, each with an assigned owner.
- A.5.12 – Classification of Information: Classify assets identified above (e.g., patient records as highly confidential) to drive proportionate control selection.
- A.6.3 – Information Security Awareness, Education & Training: Implement a recurring training programme for clinical, IT, and administrative staff, covering data handling, phishing, and incident reporting.
- A.5.19 / A.5.20 – Supplier Relationships: Introduce a supplier security due-diligence checklist and standard security clauses for supplier contracts, applied before onboarding any new third party.
- Formal Statement of Applicability (SoA): Once the risk assessment is complete, document the applicability (or justified exclusion) of all 93 Annex A controls in a single SoA, to be maintained as a living document.

5. Recommend improvements using the PDCA model

NovaCare is currently at the Plan stage of the PDCA cycle. No ISMS, documented risk process, or SoA currently exists; this gap analysis and the scope statement above represent the first concrete Plan-stage actions. The table below sets out recommended next steps across the full cycle.

PDCA Stage	Recommended Actions	Indicative Timeline
Plan	Define the ISMS scope and context; approve information security policy; conduct this gap analysis and a formal risk assessment; build the information asset inventory and risk register.	0–2 months
Do	Implement prioritised Annex A controls (starting with High-priority gaps); document the Statement of Applicability; roll out supplier due diligence checks and the security awareness programme.	2–5 months
Check	Conduct an internal audit against ISO/IEC 27001 clauses 4–10 and the SoA; test control effectiveness; hold a management review of findings.	5–7 months
Act	Remediate nonconformities from the internal audit; update policies and controls based on findings; prepare documentation for external Stage 1 (readiness) audit.	7–9 months

6. **Conclusion**

This capstone project demonstrates how a structured, ISO/IEC 27001-aligned approach can transform NovaCare Health Services informal security practices into a certifiable Information Security Management System. By defining scope, conducting a gap analysis, selecting Annex A controls on a risk basis, and sequencing improvements through the PDCA model, NovaCare can move from its current stage toward audit readiness in a structured, defensible way. The immediate priority is closing the Organisational-control gaps, policy, asset inventory, and risk register as these affects every subsequent control decision.